

IT & Information Security Policy

Narsimha Tech | Effective: 1 January 2025 | Internal Use Only

1. Purpose, Scope & Policy Framework

1.1 Purpose

This IT & Information Security Policy establishes the controls and expected behaviours required to protect Narsimha Tech's information assets, client data, and technology infrastructure from unauthorised access, disclosure, alteration, or destruction. It expands on the summary IT & Security section of the Employee Handbook.

1.2 Scope

This policy applies to all employees, consultants, contractors, and any other individual granted access to Narsimha Tech systems, networks, or data, regardless of location or device ownership (Company-issued or BYOD, where permitted).

1.3 Information Security Governance

Information security is governed by the Chief Information Security Officer (CISO), supported by an Information Security Working Group with representation from IT, Legal, HR, and each major Delivery Unit. The CISO reports security posture and material incidents to the Executive Committee and, where significant, the Board Risk Committee.

1.4 Policy Hierarchy

This policy sits beneath the Company's overarching Information Security Management Framework (aligned to ISO/IEC 27001 principles) and is supplemented by detailed technical standards (e.g., the Secure Coding Standard, the Cloud Security Baseline, and the Vendor Security Assessment Standard) maintained by the IT Security team and available on the intranet.

1.5 Shared Responsibility

While the CISO's office owns the overall security programme, every employee shares responsibility for protecting information assets through day-to-day compliance with this policy. Security is not solely an "IT problem."

2. Data Classification & Handling

2.1 Classification Tiers

All Company and client information is classified into one of four tiers:

Tier	Description	Example
Public	Information approved for public release	Press releases, published marketing material
Internal	Information for use within the Company, low sensitivity	Internal newsletters, general process documentation
Confidential	Sensitive business information requiring controlled access	Client contracts, financial forecasts, HR records
Restricted	Highest sensitivity; unauthorised disclosure could cause severe harm	Source code, security configurations, client PII, credentials

2.2 Labelling

Documents and emails containing Confidential or Restricted information should be labelled accordingly in the document header/footer or email subject line where the relevant tool supports automated classification labels.

2.3 Handling Controls by Tier

Control	Internal	Confidential	Restricted
Storage location	Approved Company systems	Approved systems with access control	Approved systems with access control + encryption at rest
Sharing externally	Generally permitted with judgement	Requires NDA / approval	Prohibited without CISO and Legal approval
Email encryption	Not required	Required for external recipients	Required, plus recipient verification

Control	Internal	Confidential	Restricted
Printing	Permitted	Discouraged; secure disposal required	Requires approval; secure disposal mandatory

2.4 Data Minimisation

Employees should collect and retain only the data genuinely necessary for the task or engagement at hand, consistent with the Company's Data Privacy Policy and applicable data protection law.

2.5 Cross-Border Data Transfer

Transfer of Confidential or Restricted data (particularly personal data) across national borders must comply with the Company's Cross-Border Data Transfer Standard, which may require specific contractual safeguards (such as Standard Contractual Clauses) depending on the jurisdictions involved; employees should consult the Data Privacy Officer before establishing a new cross-border data flow.

3. Access Control & Authentication

3.1 Principle of Least Privilege

Access to systems and data is granted strictly on a need-to-know, least-privilege basis, aligned to an employee's current role. Access is reviewed and, where no longer needed, revoked promptly upon role change or termination.

3.2 Password Standards

Passwords must be at least 12 characters, include uppercase, lowercase, digits, and symbols, and be changed every 90 days. Password reuse across the last 5 password cycles is not permitted, and passwords must not be shared with any other individual, including a manager or IT support staff (who can reset, but never need to know, a password).

3.3 Multi-Factor Authentication

Multi-Factor Authentication (MFA) is mandatory for all Company systems, including email, VPN, and any SaaS application processing Company or client data. MFA fatigue attacks (repeated approval prompts) should be reported immediately as a suspected security incident rather than approved out of frustration.

3.4 Privileged Access

Employees with privileged (administrator-level) access to systems must use a separate, dedicated privileged account distinct from their standard user account, and privileged accounts are subject to enhanced monitoring and a shorter password rotation cycle (60 days).

3.5 Access Reviews

Managers must certify their team's system access entitlements on a quarterly basis as part of the Access Review programme, confirming that each access grant remains appropriate to the individual's current role.

3.6 Joiner, Mover, Leaver Process

Access provisioning follows the standard Joiner-Mover-Leaver (JML) process: access is provisioned automatically based on role at joining; adjusted automatically (with manual review for sensitive systems) upon an internal transfer; and revoked within 24 hours of an employee's last working day, coordinated between HR and IT.

4. Endpoint & Device Security

4.1 Company-Issued Devices

Company-issued devices must run the approved endpoint detection and response (EDR) software at all times, with automatic security patching enabled. Employees must not disable, uninstall, or attempt to bypass the EDR agent.

4.2 Acceptable Use

Company-issued devices must be used exclusively for business purposes, with limited, reasonable personal use tolerated (e.g., checking personal email) provided it does not violate this policy or introduce undue risk.

4.3 Prohibited Actions

Employees must not: install unauthorised software; use personal USB drives or external storage on company hardware without IT approval; leave workstations unlocked when unattended; or disable security controls such as screen lock timers.

4.4 Screen Lock and Physical Security

Devices must be configured to automatically lock after a maximum of 5 minutes of inactivity, and employees must manually lock their screen (Windows+L or equivalent) whenever stepping away from their workstation, even briefly.

4.5 Bring Your Own Device (BYOD)

Where permitted for limited use cases, personal devices must be enrolled in the Company's Mobile Device Management (MDM) system, which enforces a security baseline (passcode, encryption, remote wipe capability) and allows IT to remotely wipe Company data (but not personal data) from the device upon offboarding or loss.

4.6 Loss or Theft

Any lost or stolen device — Company-issued or BYOD-enrolled — must be reported to IT Security immediately (within 1 hour where possible) so that remote wipe and credential revocation can be initiated without delay.

4.7 Removable Media

Use of removable media (USB drives, external hard disks) is restricted by default at the device level; exceptions require IT approval and, where approved, mandatory encryption of the removable media.

4.8 End-of-Life Device Disposal

Retired Company devices must be returned to IT for secure data wiping and environmentally responsible disposal or recycling; employees must never dispose of a Company device themselves, even one they have purchased from the Company at the end of its lifecycle, without IT-certified data wiping first.

5. Network & Remote Access Security

5.1 VPN Requirement

Use of public Wi-Fi (e.g., at a café, airport, or hotel) is prohibited unless a company-issued VPN is active for the duration of the connection.

5.2 Home Network Security

Employees working from home are expected to secure their home Wi-Fi network with a strong, unique password and up-to-date router firmware; IT provides basic guidance on home network security via the intranet Wellbeing/IT Tips page.

5.3 Public Wi-Fi and Travel

When travelling (per the Global Travel Policy), employees should treat hotel and conference Wi-Fi as inherently untrusted and connect via VPN at all times, and should be alert to "evil twin" Wi-Fi networks mimicking a legitimate venue network.

5.4 Network Segmentation

Internal Company networks are segmented such that guest and visitor network access (Section 14.4 of the Employee Handbook) is logically separated from the corporate network carrying Confidential and Restricted data.

5.5 Firewall and Perimeter Controls

IT Security maintains firewall and intrusion detection/prevention controls at the network perimeter, with logs retained per the Records Retention Schedule and reviewed as part of the Security Operations Centre's (SOC) monitoring programme.

6. Software, Cloud & Third-Party Risk

6.1 Approved Software Catalogue

All software installed on Company devices, and all SaaS applications used for business purposes, must be approved through the IT Software Catalogue. Requests for new tools should be raised via the IT Service Desk.

6.2 Shadow IT

Use of unapproved ("shadow IT") tools for business purposes, particularly for any activity involving Confidential or Restricted data, is prohibited, as such tools have not been assessed for security, data residency, or contractual data protection terms.

6.3 Generative AI Tool Approval

As referenced in the Code of Conduct & Business Ethics Policy, Section 8.4, generative AI tools must be specifically approved by IT Security for use with Confidential or Restricted data before such data is input into the tool; a list of currently approved AI tools, and the data classifications each is approved for, is maintained on the intranet.

6.4 Cloud Infrastructure

Cloud infrastructure provisioned for Company or client workloads must follow the Cloud Security Baseline, including mandatory encryption at rest and in transit, network security group configuration review, and tagging for cost and ownership tracking.

6.5 Vendor and Third-Party Security Assessment

Any new vendor or third party that will process Confidential or Restricted data on the Company's behalf must complete a Vendor Security Assessment, coordinated by Procurement and IT Security, before the engagement begins, including review of the vendor's own security certifications where available (e.g., SOC 2, ISO 27001).

6.6 Open Source Software

Use of open-source components in Company or client deliverables must comply with the Open Source Usage Policy, including license compatibility review and vulnerability scanning of open-source dependencies (e.g., via automated software composition analysis tooling) before release.

7. Email, Messaging & Social Engineering Defence

7.1 Phishing Awareness

Employees must complete mandatory phishing and social engineering awareness training within 30 days of joining and annually thereafter, and must report suspected phishing emails using the "Report Phishing" button in the corporate email client rather than simply deleting them.

7.2 Simulated Phishing Campaigns

IT Security periodically runs simulated phishing campaigns to assess and improve organisational resilience; employees who interact with a simulated phishing email receive targeted micro-training rather than disciplinary action, reflecting the Company's preference for a learning-oriented approach to this particular control.

7.3 Business Email Compromise (BEC)

Employees handling payment instructions or sensitive requests received by email must independently verify any request to change payment details, urgent wire transfer instructions, or unusual requests from a senior executive, via a separate communication channel (e.g., a phone call to a known number), before acting, given the prevalence of Business Email Compromise fraud targeting exactly this scenario.

7.4 Suspicious Attachments and Links

Employees should not open attachments or click links from unknown or unexpected senders, and should hover over links to verify the actual destination URL before clicking, even when the email appears to come from a known contact (whose account may itself be compromised).

7.5 Voice and SMS-Based Social Engineering ("Vishing" / "Smishing")

Employees should apply the same scepticism to unexpected phone calls or text messages requesting credentials, MFA codes, or sensitive information as they would to email, and should never share an MFA code with anyone, including someone claiming to be from IT Support (legitimate IT Support never needs an employee's MFA code).

8. Security Incident Management

8.1 What Constitutes an Incident

A security incident includes, without limitation: a suspected phishing compromise; loss or theft of a device or storage media; unauthorised access to a system or account; malware infection; and any data breach involving Confidential, Restricted, or personal data.

8.2 Reporting Obligation

Suspected security incidents must be reported immediately to security@narsimhatech.com and the CISO's office. Early reporting of even a suspected near-miss is encouraged and not penalised provided it is made promptly and in good faith.

8.3 Incident Response Process

Upon receiving a report, the Security Operations Centre triages the incident, contains the affected system or account (e.g., by disabling credentials or isolating a device from the network), investigates root cause, and remediates, following the documented Incident Response Plan.

8.4 Severity Classification

Severity	Example	Initial Response Target
Critical	Active data breach involving client Restricted data	Immediate (within 1 hour)
High	Confirmed malware on a device with system access	Within 4 hours
Medium	Suspected phishing click, no confirmed compromise	Within 1 business day
Low	Policy query or minor non-compliant configuration	Within 3 business days

8.5 Client and Regulatory Notification

Where an incident involves client data or personal data subject to a notification obligation under applicable law, Legal and the Data Privacy Officer determine and execute any required client or regulatory notification within the applicable statutory timeframe (which, in some jurisdictions, can be as short as 72 hours from discovery).

8.6 Post-Incident Review

Following resolution of any Medium-severity or higher incident, a post-incident review is conducted to identify root cause and any control gap, with remediation actions tracked to closure by IT Security.

9. Business Continuity & Disaster Recovery

9.1 Business Continuity Planning

Each Delivery Unit and corporate function maintains a Business Continuity Plan (BCP) identifying critical processes, dependencies, and recovery procedures in the event of a disruptive incident (system outage, office unavailability, regional disaster).

9.2 Disaster Recovery for Systems

IT maintains a Disaster Recovery Plan for critical systems, including defined Recovery Time Objectives (RTO) and Recovery Point Objectives (RPO) for each system tier, tested at least annually.

9.3 Backup Policy

Critical business and client data is backed up according to a schedule appropriate to its criticality, with backups encrypted and periodically tested for restorability; employees should not rely on local device storage as the sole copy of any business-critical file.

9.4 Crisis Communication

In the event of a major incident affecting business operations, Corporate Communications coordinates internal and, where necessary, external communication, with employees directed to official channels (intranet banner, mass notification system) rather than informal channels for authoritative updates.

10. Application & Software Development Security

10.1 Secure Development Lifecycle

Engineering teams building software for clients or internal use must follow the Secure Development Lifecycle (SDLC), incorporating security requirements gathering, secure design review, secure coding standards, and security testing (static analysis, dependency scanning, and, for higher-risk applications, penetration testing) before release.

10.2 Secure Coding Standards

All engineers must complete secure coding training relevant to their primary language/framework and must follow the Secure Coding Standard maintained by the Engineering Standards team, covering common vulnerability classes (e.g., injection, broken access control, insecure deserialization).

10.3 Code Review and Peer Review

All code changes to production systems must undergo peer review before merge, with security-relevant changes (authentication, authorisation, cryptography) requiring review by a designated security champion within the team.

10.4 Credential and Secrets Management

Hard-coding credentials, API keys, or other secrets directly in source code is strictly prohibited; secrets must be managed through an approved secrets management solution, with automated scanning of repositories to detect any accidental secret commits.

10.5 Penetration Testing and Vulnerability Management

Client-facing applications handling Confidential or Restricted data undergo penetration testing at least annually or upon material architecture change, with identified vulnerabilities tracked to remediation within timeframes proportional to severity (Critical: 7 days; High: 30 days; Medium: 90 days).

11. Physical Security

11.1 Office Access Control

Physical access to Company offices is controlled via badge access, with visitor access managed per the Visitor Policy described in the Employee Handbook, Section 14.4.

11.2 Data Centre and Server Room Access

Access to any on-premises server room or data centre facility is restricted to authorised IT personnel and logged, with periodic access review consistent with Section 3.5.

11.3 Clean Desk Practice

Employees handling physical Confidential or Restricted documents should adopt a clean desk practice, securing such documents in a locked drawer or cabinet when not actively in use, particularly overnight.

11.4 Secure Disposal

Physical documents containing Confidential or Restricted information must be disposed of via the secure shredding bins provided at each office location, not standard waste bins.

12. Monitoring & Acceptable Use of Company Systems

12.1 Monitoring Notice

The Company reserves the right to monitor use of Company systems, networks, and devices (including email, internet usage, and device activity logs) for security, legal compliance, and legitimate business purposes, consistent with applicable local law and any required employee notice.

12.2 Investigatory Access

Where required for a disciplinary investigation, security incident response, or legal proceeding, IT Security may access an employee's Company email or device data, with appropriate authorisation from HR, Legal, or the CISO depending on the nature of the matter.

12.3 Personal Privacy on Company Systems

Employees should have no expectation of privacy in content created, stored, or transmitted using Company systems, including personal communications sent via Company email or chat tools, even where incidental personal use is otherwise tolerated under Section 4.2.

12.4 Acceptable Use Boundaries

In addition to the prohibitions in Section 4.3, Company systems must never be used to: access, store, or distribute illegal content; engage in harassment or discrimination prohibited under the Employee Handbook; or conduct any unauthorised commercial activity unrelated to Company business.

13. Roles, Training & Governance

13.1 CISO Office

The CISO's office sets security policy and standards, operates the Security Operations Centre, and reports security posture and incidents to the Executive Committee and Audit Committee.

13.2 IT Service Desk

The IT Service Desk handles day-to-day access requests, software requests, and device support, escalating any security-relevant request (e.g., a request to disable MFA) to IT Security for review rather than actioning it directly.

13.3 Security Champions

Each Delivery Unit nominates a Security Champion who acts as a liaison between the team and the CISO's office, helping to embed secure practices into day-to-day delivery work and surfacing team-specific security questions or concerns.

13.4 Mandatory Training Cadence

Training	Audience	Frequency
General security awareness & phishing	All employees	Annual, plus within 30 days of joining
Secure coding	Engineering roles	Annual
Data privacy fundamentals	All employees	Annual
Privileged access security	Employees with admin-level access	Annual, plus upon privileged access grant

13.5 Non-Compliance

Failure to comply with this policy is addressed through the disciplinary process described in the Terms of Employment, with severity assessed based on factors such as intent, data sensitivity involved, and whether the non-compliance contributed to an actual security incident.

14. Frequently Asked Questions

Q: Can I check my personal email on my Company laptop?

A: Limited, reasonable personal use is generally tolerated per Section 4.2, but be mindful that personal email is not covered by Company security controls; never use personal email to receive or send Company Confidential or Restricted data.

Q: IT called me asking for my password to fix an issue remotely — should I give it to them?

A: No — legitimate IT Support never needs your password or MFA code (Section 7.5). Decline and report the call to security@narsimhatech.com as a suspected vishing attempt.

Q: I accidentally clicked a link in a phishing email — what should I do?

A: Report it immediately via security@narsimhatech.com or the Report Phishing button; immediate, honest reporting is encouraged and not penalised (Section 8.2), and allows IT Security to contain any potential compromise quickly.

Q: Can I use a free, consumer-grade AI chatbot to help draft a client proposal?

A: Only for non-sensitive drafting that does not involve inputting any Confidential or Restricted client data; check the approved AI tools list on the intranet (Section 6.3) before inputting any client-specific information into any AI tool.

Q: My personal phone is enrolled in MDM — can IT see my personal photos and messages?

A: No — MDM enrolment for BYOD is scoped to manage and, if necessary, wipe only the Company data/work profile on the device; it does not give IT visibility into personal content (Section 4.5).

15. Mobile & IoT Device Considerations

15.1 Mobile Application Management

Company-managed mobile devices and BYOD work profiles use Mobile Application Management (MAM) controls to restrict copy/paste of Company data into unapproved personal apps and to enforce app-level encryption for Company email and document apps.

15.2 IoT and Smart Devices in Office Locations

Internet of Things (IoT) devices in office locations (smart printers, conference room systems, badge readers) are provisioned and patched by IT Facilities Technology and placed on a segregated network, separate from the corporate data network described in Section 5.4.

15.3 Personal Smart Assistants in Home Offices

Employees working from home with voice-activated smart assistants (e.g., smart speakers) in their workspace should be mindful of placement during calls involving Confidential or Restricted discussions, and should mute or relocate such devices during sensitive conversations.

16. Data Privacy Deep Dive

16.1 Relationship to the Data Privacy Policy

This section summarises the data privacy principles most relevant to day-to-day IT and information handling; the standalone Data Privacy Policy provides full detail, including the Company's role as data controller or processor in different contexts and data subject rights handling procedures.

16.2 Personal Data Inventory

Each system or process that handles personal data must be recorded in the Company's Personal Data Inventory, maintained by the Data Privacy Officer, documenting the categories of data, purpose, retention period, and any third parties with access.

16.3 Privacy by Design

New systems, products, or significant process changes involving personal data must undergo a Data Privacy Impact Assessment (DPIA) at the design stage, coordinated with the Data Privacy Officer, to identify and mitigate privacy risks before implementation rather than retrofitting controls afterward.

16.4 Data Subject Rights Requests

Requests from individuals to access, correct, or delete their personal data held by the Company (data subject rights requests) must be forwarded immediately to the Data Privacy Officer, who coordinates the response within the statutory timeframe applicable to the relevant jurisdiction; employees must not attempt to independently fulfil such a request without DPO involvement.

16.5 Anonymisation and Pseudonymisation

Where feasible, particularly for analytics or testing purposes, personal data should be anonymised or pseudonymised to reduce risk, consistent with the data minimisation principle in Section 2.4.

17. Glossary

- **CISO:** Chief Information Security Officer, responsible for the Company's overall information security programme.
- **EDR:** Endpoint Detection and Response, security software monitoring devices for malicious activity.
- **MFA:** Multi-Factor Authentication, requiring more than one form of verification to access a system.
- **MDM/MAM:** Mobile Device Management / Mobile Application Management, tools used to secure devices and apps used for Company data.
- **DPIA:** Data Privacy Impact Assessment, a structured risk assessment for new processes involving personal data.
- **SOC:** Security Operations Centre, the team monitoring and responding to security events.
- **RTO/RPO:** Recovery Time Objective / Recovery Point Objective, disaster recovery targets for system restoration.

18. Document Control

Attribute	Detail
Document Owner	Chief Information Security Officer (CISO)
Review Frequency	Annual, or upon material change in threat landscape or regulation
Last Reviewed	January 2025
Related Documents	Terms of Employment; Employee Handbook; Code of Conduct & Business Ethics Policy; Data Privacy Policy; Cloud Security Baseline; Secure Coding Standard